

PROFIL ORGANIZACJI - SecureEdge Solutions Sp. z o.o.

1. KIM JESTEŚMY

Nazwa firmy: SecureEdge Solutions Sp. z o.o.

Czym się zajmujemy: Szkolenia z cyberbezpieczeństwa dla firm

Rok powstania: 2023 (młoda firma, 2 lata na rynku)

Gdzie działamy: Warszawa (jedno biuro)

Ile mamy ludzi: 100 pracowników

Jak pracujemy:

- 70% pracuje zdalnie z domu
- 30% przychodzi do biura w Warszawie
- Wszyscy mają laptopy firmowe

Kto u nas pracuje:

70 osób - Techniczny zespół

- └ 30 programistów (robią platformę szkoleniową)
- └ 25 trenerów i twórców contentu (robią materiały szkoleniowe)
- └ 10 DevOps (zarządzają serwerami)
- └ 5 specjalistów od phishingu (wysyłają testowe ataki dla klientów)

20 osób - Sprzedaż i marketing

- └ Sprzedają szkolenia firmom

10 osób - Administracja

- └ 3 szefów (CEO, CTO, CPO)
- └ 2 osoby IT (pomagają jak coś nie działa)
- └ 2 osoby HR (zatrudnianie)
- └ 3 osoby księgowość/prawnik/biuro

Kim są założyciele (ważne!):

- **CEO Tomasz:** Biznesmen, wcześniej sprzedaż w firmie SaaS
- **CTO Paweł:** Dobry programista, ale NIE zna się na zabezpieczeniach serwerów
- **CPO Kasia:** Designer, tworzy interfejsy

Dlaczego to ważne: Założyciele nie są specjalistami od bezpieczeństwa. Zobaczyli że firmy potrzebują szkoleń, zrobili produkt, ale sami nie wiedzą jak zabezpieczyć własną firmę.

2. CO SPRZEDAJEMY

Nasz główny produkt:

SecureEdge Academy - platforma szkoleniowa w chmurze

- Firmy kupują dostęp dla swoich pracowników
- Pracownicy oglądają filmy o bezpieczeństwie, rozwiązują quizy
- Cena: 20-80 PLN za osobę miesięcznie
- Mamy 95 firm-klientów (~8,000 osób się szkoli)

Dodatkowo: Symulacje phishingu

- Wysyłamy fałszywe emaily phishingowe do pracowników klientów (za zgodą firmy)
- Sprawdzamy kto kliknie
- Cena: 5,000 PLN miesięcznie
- 60 firm korzysta

Nasi klienci:

- 12 banków
- 30 sklepów internetowych
- 15 przychodni/szpitali
- 20 fabryk
- 18 innych firm

Największy klient: Bank regionalny - płaci 180,000 PLN rocznie za szkolenia dla 2,000 swoich pracowników

3. NASZE KOMPUTERY I SERWERY

Laptopy pracowników (105 sztuk):

50 MacBooków - programiści, designerzy

40 Delli z Windowsem 11 - sprzedaż, biuro, trenerzy

15 ThinkPadów z Linuxem - DevOps

Telefony:

- 60 iPhone'ów firmowych (szefowie i sprzedaż)
- Reszta ma swoje prywatne

Problem:

-  Każdy laptop ma inny antywirus (albo wcale)
-  Nikt tym centralnie nie zarządza
-  Nie wiemy co się dzieje na laptopach

Nasze serwery (7 sztuk):

Wszystkie są w chmurze AWS (Amazon):

Serwer 1: Strona internetowa platformy

└ Tu użytkownicy logują się do szkoleń

Serwer 2: API (mózg systemu)

└ Obsługuje wszystkie akcje (logowanie, postęp, quizy)

Serwer 3: Baza danych

└ Tu są zapisane dane klientów, wyniki szkoleń

Serwer 4: Serwer plików

└ Udostępnione foldery dla zespołu

Serwer 5: Zarządzanie użytkownikami (FreeIPA)

└ Lista kto pracuje w firmie, kto ma dostęp do czego

Serwer 6: Testowy (staging)

└ Programiści testują tu nowe funkcje

└ ⚠ PROBLEM: Czasem kopiujemy tu prawdziwe dane klientów

Serwer 7: NAS w biurze (Synology)

└ Kopie zapasowe, udostępnione pliki

└ To jedyny fizyczny serwer, reszta w AWS

Email: Microsoft 365 (w chmurze, nie mamy własnego serwera pocztowego)

Programy których używamy codziennie:

Email i rozmowy:

- ├─ Microsoft 365 (email, OneDrive)
- ├─ Slack (chat firmowy)
- └─ Teams (video rozmowy)

Praca:

- ├─ GitHub (kod programu)
- ├─ Linear (zarządzanie projektami)
- ├─ Notion (wiki firmowa, dokumenty)
- └─ HubSpot (lista klientów, sprzedaż)

Logowanie:

- └─ Okta (jeden login do wszystkiego)

Nasza sieć (internet i WiFi):

W biurze w Warszawie:

Internet:

- └─ Światłowód 500 Mb/s (Orange Business)

Sprzęt:

- ├─ 1 router/firewall (Ubiquiti Dream Machine Pro)
- ├─ 2 switchy sieciowe (Ubiquiti)
- └─ 4 punkty WiFi (Ubiquiti)

WiFi dla pracowników: "SecureEdge-Corporate"

WiFi dla gości: "SecureEdge-Guest" (oddzielony od reszty)

Sieć podzielona na 4 części (VLANy):

- └─ VLAN 10: Laptopy pracowników
- └─ VLAN 20: Serwer NAS, drukarki
- └─ VLAN 30: WiFi dla gości
- └─ VLAN 40: Smart TV, ekspres do kawy

VPN (dostęp zdalny):

- Program: Tailscale
- ⚠️ PROBLEM: Wszyscy 100 pracowników ma VPN, nawet ci którzy nie potrzebują

W chmurze AWS:

Nasza prywatna sieć w AWS:

- └─ Sieć publiczna: Tu jest strona www (dostępna z internetu)
- └─ Sieć prywatna: Tu są nasze serwery (nieдоступne z internetu)
- └─ Sieć baz danych: Tu jest baza (najbardziej chroniona)

Firewall: AWS Security Groups (15 różnych zasad)

Kopie zapasowe:

Co robimy:

- ✅ Baza danych: Automatyczna kopia codziennie (7 dni wstecz)
- ❌ Serwery: Robimy ręcznie, czasem zapominamy
- ✅ NAS w biurze: Automatyczna kopia co godzinę
- ✅ Kod: GitHub automatycznie zapisuje
- ❌ Laptopy: Nie ma obowiązku robienia kopii

Problemy:

- ❌ Nigdy nie sprawdziliśmy czy da się odzyskać dane z kopii
- ❌ Kopie można skasować (nie są zabezpieczone)
- ❌ Nie mamy planu "co robić jak wszystko padnie"

Zespół IT (2 osoby):

Marcin (Lead DevOps):

- └─ Zarządza AWS, stawia serwery, naprawia jak coś nie działa

Ania (IT Support):

└ Pomaga pracownikom, daje nowe laptopy, robi onboarding

Kto pilnuje bezpieczeństwa?

-  NIKT konkretnie
- CTO teoretycznie powinien, ale zajmuje się produktem
- Nie ma osoby która codziennie sprawdza "czy jesteśmy bezpieczni"

4. CO JEST DLA NAS WAŻNE

Co MUSI działać (inaczej tracimy klientów):

Krytyczne:

1. Platforma szkoleniowa (klienci nie mogą się szkolić = tracą pieniądze)
2. Wysyłanie phishingów (klienci płacą za tę usługę)
3. Raporty dla klientów (muszą widzieć postępy)

Ważne: 4. HubSpot (baza klientów - bez tego sprzedaż stoi) 5. Email i Slack (100 osób nie może się dogadać) 6. GitHub (programiści nie mogą pracować)

Jakie dane mamy:

Dane klientów (NAJWAŻNIEJSZE):

- └ Listy pracowników firm-klientów (8,000 osób)
- | └ Imiona, nazwiska, emaile, działy
- └ Wyniki szkoleń (kto ukończył, jakie punkty)
- └ Wyniki testów phishingowych (kto kliknął w fake phishing)
- └ Kontakty szefów (HR managerowie, CISOs w firmach klientów)

Nasze dane:

- └ Kod naszego programu (najcenniejsze - to nasz produkt!)
- └ 250+ filmów szkoleniowych (nagraliśmy sami)
- └ Dane pracowników (umowy, wynagrodzenia)
- └ Dokumenty firmowe (kontrakty z klientami, faktury)

Problem:

-  Nie mamy zasad "co jest tajne, a co nie"
-  Pracownicy nie wiedzą czego nie wolno wysyłać mailem

Przepisy których musimy przestrzegać:

Teraz:

-  RODO - podstawowe (mamy politykę prywatności)
-  ISO 27001 - planujemy zrobić (koniec 2025)
-  SOC 2 - 2 najwięksi klienci wymagają (musimy mieć do września 2025)

Audyty:

- Zewnętrzna firma sprawdzała nas (maj 2024)
- Znaleźli 15 problemów, 2 KRYTYCZNE
-  **Nie naprawiliśmy krytycznych** - "nie było czasu, robimy nową funkcję"

5. CO JUŻ MAMY (zabezpieczenia)

Co działa dobrze:

Logowanie:

-  Okta SSO (jeden login do wszystkich programów)
-  Musimy podać kod z telefonu żeby się zalogować (MFA)
-  Ale AWS nie wymaga kodu z telefonu 

Sieć:

-  Mamy firewall (w AWS i w biurze)
-  Mamy VPN do pracy zdalnej

Szyfrowanie:

-  Dyski w laptopach zaszyfrowane
-  Baza danych zaszyfrowana
-  Wszystkie połączenia przez HTTPS

Czego NIE MAMY (dziury):

Ochrona laptopów:

-  Brak profesjonalnego antywirusa (tylko te wbudowane w system)
-  Nikt nie zarządza antywirusami centralnie
-  Nie zarządzamy telefonami (ludzie mają prywatne)

Monitoring (kto co robi):

-  AWS zapisuje wszystko w logach, ale NIKT ich nie czyta

- ❌ Nie mamy alertów jak ktoś robi coś dziwnego (np. loguje się w nocy)
- ❌ Nie wiemy kto co pobiera z serwerów

Ochrona przed wyciekami:

- ❌ Pracownik może spokojnie wysłać wszystko na swojego prywatnego Gmail/Dropbox
- ❌ Nikt tego nie wykryje

Aktualizacje:

- ❌ Nie skanujemy regularnie czy mamy dziury w zabezpieczeniach
- ❌ Nie ma automatycznych aktualizacji

Zasady i procedury:

- ⚠️ Hasła: "minimum 8 znaków, 1 cyfra" (za słabe!)
- ❌ Nie mamy instrukcji "co robić jak będzie atak"
- ❌ Nie mamy listy naszego sprzętu (nie wiemy dokładnie co mamy)

Szkolenia (IRONIA!):

- ⚠️ Nowi pracownicy: 1 godzina webinaru o bezpieczeństwie (z naszego produktu)
- ❌ Potem nigdy więcej szkoleń
- ❌ Nie testujemy własnych ludzi phishingiem (szewc bez butów!)

6. CO SIĘ DZIAŁO WCZEŚNIEJ (ostrzeżenia)

4 sygnały że coś jest nie tak:

1. Ktoś próbował nas zphishować (kwiecień 2024):

- 8 pracowników dostało fałszywego emaila
- 2 osoby kliknęły
- 1 osoba wpisała hasło
- ✅ Nas uratowało że trzeba podać kod z telefonu (MFA)
- ❌ Nikt potem nie sprawdził "jak to się mogło stać"

2. Zgubiony laptop (lipiec 2024):

- Pracownica zostawiła MacBooka w kawiarni
- Dysk był zaszyfrowany ✅
- ALE: Chrome był zalogowany do 10 programów firmowych ❌
- Skasowaliśmy laptopa zdalnie po 36 godzinach

3. Audyt znalazł 2 KRYTYCZNE problemy - NIE NAPRAWILIŚMY (maj 2024):

Co znaleźli:

└ Środowisko testowe dostępne z internetu (każdy mógł wejść)

└ Jeden folder w AWS był publicznie dostępny

Nasza odpowiedź:

"Naprawimy po wakacjach, teraz nie mamy czasu,
robimy nową funkcję dla klientów"

Status: DO DZIŚ NIE NAPRAWIONE ❌

4. Dziwne logowania - ZIGNOROWANE (listopad 2024):

Ania (IT) zauważyła:

- Młodszy programista (Piotr K.) loguje się do AWS o 2-3 w nocy
- Dużo pobiera plików z serwera (zauważyła przypadkiem)

Powiedziała Marcinowi (DevOps).

Odpowiedź: "To dobrze że pracuje w nocy, pewnie testuje coś. Daj mu spokój."

❌ Nikt nie sprawdził CO dokładnie robi

7. CO SIĘ STAŁO - GŁÓWNY WYCIEK

Historia krok po kroku:

CZERWIEC 2024: Zatrudniliśmy Piotra

Kim był:

└ Junior Programista

└ CV wyglądało OK (1.5 roku doświadczenia)

└ Przeszedł 2 rozmowy kwalifikacyjne (zadania z kodowania)

└ Referencje: sprawdziliśmy emailiem (pozytywne)

❌ NIE ZROBILIŚMY:

└ Background check (kosztował 2,000 PLN, uznaliśmy że za drogo dla juniora)

Dostał:

- └─ Laptopa MacBook Pro
- └─ Konto email: piotr.kowalski@secureedge.pl
- └─ Dostęp do Slack, GitHub, Notion
- └─ Dostęp do AWS (tylko czytanie na początku)
- └─ VPN (dostęp do wszystkiego)

SIERPIEŃ 2024: Piotr poprosił o więcej dostępów

Wiadomość na Slacku do Marcina (DevOps):

"Cześć! Pracuję nad nową funkcją (optymalizacja video). Muszę przetestować na środowisku testowym z prawdziwymi danymi. Możesz mi dać dostęp?"

Marcin odpowiedział:

"Jasne, dodałem Cię do grupy developers. Powinno działać."

Co dostał (ZA DUŻO!):

Dostęp do AWS:

- └─ Mógł czytać/zapisywać wszystkie pliki testowe
- └─ Mógł odczytać hasła do bazy danych! ⚠ ⚠
- └─ Mógł wejść na serwer testowy

Serwer testowy:

- └─ 40% fałszywych danych (do testów)
- └─ 60% PRAWDZIWYCH danych klientów ⚠ ⚠

(programiści skopiowali z produkcji 2 miesiące temu żeby testować)

Błędy:

-  Marcin sam zdecydował (nikt nie sprawdził czy to OK)
-  Nie było limitu czasowego (miał dostęp na zawsze)
-  Nikt nie sprawdzał "czy nadal potrzebuje" po miesiącu

PAŹDZIERNIK 2024: Piotr zaczął kraść dane

Co robił (w nocy, 2-4 rano):

1. Zalogował się do AWS
2. Odczytał hasło do bazy testowej
3. Wszedł do bazy
4. Skopiował 2,100 danych klientów
5. Uploadował na swojego prywatnego AWS-a (1.8 GB)

Powtórzył to 8 razy w ciągu 3 tygodni.

✗ NIKT TEGO NIE ZAUWAŻYŁ

- AWS zapisywał logi
- Ale nikt ich nie czytał
- Nie było alertów

Ostrzeżenie (zignorowane):

- Ania zauważyła że Piotr loguje się w dziwnych godzinach
- Marcin: "Niech pracuje, dobrze że jest zmotywowany"

LISTOPAD 2024: Piotr się zwalnia

Email do HR (28 listopada):

"Dziękuję za 5 miesięcy pracy. Dostałem ofertę z innego startupa (equity package). 2 tygodnie wypowiedzenia, ostatni dzień: 12 grudnia."

Co zrobiliśmy przy zwalnianiu:

- ✓ Odebraliśmy laptop (12 grudnia)
- ✓ Odebraliśmy kartę wejściową do biura
- ✓ Wyłączyliśmy konto email (automatycznie)

✗ NIE ZROBILIŚMY:

- └ Nie usunęliśmy konta AWS
- └ Nie sprawdziliśmy czy nie stworzył dodatkowych kont
- └ Nie zmieniliśmy haseł do których miał dostęp
- └ Nie wyłączyliśmy VPN
- └ Nie sprawdziliśmy co robił ostatnie tygodnie

GRUDZIEŃ 2024: Piotr wraca (zdalnie)

13-15 grudnia (WEEKEND, 2 dni po zwolnieniu):

Piotr wciąż miał:

- └ Konto AWS (nie usunięte)
- └ VPN (nie wyłączony)
- └ Znał hasła (nie zmienione)

Co zrobił:

1. Włączył VPN z domu
2. Zalogował się do AWS (jego stare konto działało!)
3. Wszedł do PRODUKCYJNEJ bazy danych
4. Zrobił pełną kopię (2.4 GB)
5. Uploadował na swojego prywatnego AWS-a

Łącznie ukradł:

- └ Dane 8,900 użytkowników z 52 firm-klientów
- └ Wszystkie wyniki testów phishingowych
- └ Listę wszystkich naszych klientów z kontaktami
- └ Dokumenty firmowe

18 GRUDNIA: Klient dzwoni - ODKRYCIE

Email od CISO naszego największego klienta (banku):

TEMAT: PILNE - Wyciek danych

Dzień dobry,

Konkurencja ma NASZE dane:

- Wyniki phishingów z listopada
- Listę naszych działów
- Nazwiska naszych pracowników

To mogło wyjść TYLKO od Was.

Zawieszamy kontrakt natychmiast. Macie 24h na wyjaśnienia.

Rozważamy pozew.

Jan Kowalski, CISO

8. CO STRACILIŚMY

Pieniądze:

- └ 3 klientów zerwało umowy: 120,000 PLN rocznie
- └ Eksperci którzy pomogli zbadać incydent: 60,000 PLN
- └ Prawnik: 35,000 PLN
- └ Firma PR (naprawa wizerunku): 20,000 PLN
- └ RAZEM: ~350,000 PLN

+ Możliwa kara od UODO (w toku)

Reputacja:

- └ Artykuły w prasie: "Firma ucząca bezpieczeństwa została zhakowana"
- └ Potencjalni klienci pytają: "Jak u was był wyciek?"
- └ Sprzedaż spadła o 40%

Certyfikaty:

- └ SOC 2 opóźnione o 6 miesięcy (klienci wymagają, nie będzie na czas)

Dane:

52 firmy-klientów straciło dane:

- ├ Listy pracowników (8,900 osób)
- ├ Wyniki szkoleń
- ├ Wyniki testów phishingowych
- └ Dokumenty wewnętrzne

Musieliśmy zgłosić do UODO (urząd ochrony danych)

9. DLACZEGO TO SIĘ STAŁO

4 główne przyczyny:

1. Zła kontrola dostępów

- ├ Piotr dostał za dużo uprawnień (więcej niż potrzebował)
- ├ Środowisko testowe miało prawdziwe dane (nie powinno)
- ├ Nikt nie sprawdzał "czy nadal potrzebuje dostępu"
- └ Przy zwalnianiu: zabraliśmy laptop, ale nie usunęliśmy dostępu AWS/VPN

2. Zero monitoringu

- ├ AWS zapisywał wszystko co Piotr robił
- ├ Ale NIKT tych logów nie czytał
- ├ Nie było alertów (np. "ktoś loguje się o 2 w nocy")
- └ Nie wiedzieliśmy że kradnie dane dopóki klient nie zadzwonił

3. Brak ochrony przed wyciekami

- ├ Piotr mógł spokojnie uploadować gigabajty gdzie chciał
- ├ Nikt tego nie wykrył
- └ Nie mamy programów które sprawdzają "czy ktoś wysyła poufne dane"

4. Zła kultura bezpieczeństwa

- ├ Założyciele nie znają się na security operations
- ├ Priorytet: "zrobmy funkcję szybko" > "zrobmy bezpiecznie"

- └ Ostrzeżenia ignorowane ("pewnie ćwiczysz coś w nocy")
- └ Audyt znalazł krytyczne błędy - nie naprawiliśmy (brak czasu)

10. CO TERAZ (Styczeń 2025)

Wiadomość od CEO (31 grudnia 2024):

Do całego zespołu,

Grudzień był najgorszy w historii SecureEdge. Uczymy inne firmy bezpieczeństwa, a sami popełniliśmy podstawowe błędy.

Co robimy:

1. Zatrudniamy CISO - pierwszą osobę odpowiedzialną TYLKO za bezpieczeństwo (luty 2025)
2. **[Janusz L]** - prowadzisz pełny projekt naprawczy Potrzebujemy od Ciebie:
 - Analiza: co poszło nie tak
 - Ryzyka: co jeszcze może pójść nie tak
 - Plan: jak to naprawimy
 - Harmonogram i koszty
3. SOC 2 certification - MUST HAVE (wrzesień 2025)
4. Budżet na security: 12% budżetu IT (było 3%)

Masz pełne wsparcie zarządu i zasoby. Nie możemy pozwolić na powtórkę.

Tomasz S. CEO

GAP ANALYSIS - SecureEdge Solutions

CO TO JEST GAP ANALYSIS?

Gap Analysis = Analiza Luk

Porównanie:

- **CO MAMY** (obecny stan)
- **CO POWINNIŚMY MIEĆ** (według CIS Controls IG1)
- **CO NAM BRAKUJE** (luka)

CIS CONTROLS IG1 - CO TO?

CIS Controls = 18 obszarów bezpieczeństwa

IG1 = 56 podstawowych zabezpieczeń dla małych/średnich firm

Dlaczego CIS IG1?

-  Dla firm 100-1000 osób
 -  Realistyczny (56 rzeczy, nie 500)
 -  Darmowy
 -  Pokrywa wszystko co poszło nie tak w naszym incydencie
-

18 KONTROLI CIS

1. Spis sprzętu
 2. Spis programów
 3. Ochrona danych
 4. Bezpieczna konfiguracja
 5. Zarządzanie kontami
 6. Kontrola dostępów
 7. Zarządzanie podatnościami
 8. Logi (kto co robi)
 9. Ochrona email/przeglądarek
 10. Ochrona przed wirusami
 11. Kopie zapasowe
 12. Zarządzanie siecią
 13. Monitoring sieci
 14. Szkolenia security
 15. Zarządzanie dostawcami
 16. Bezpieczeństwo aplikacji
 17. Reagowanie na incydenty
 18. Testy bezpieczeństwa
-

GAP ANALYSIS - TOP LUKI

KONTROLA 1: SPIS SPRZĘTU

Co sprawdzamy	Status	Gap	Priorytet
Mamy listę wszystkich laptopów/serwerów?	 BRAK	Nie wiemy ile mamy, kto co ma	 KRYTYCZNY
Każdy sprzęt ma właściciela?	 BRAK	Nie zapisujemy "Laptop #123 = Jan Kowalski"	 WYSOKI

Rekomendacja:

- Szybko: Excel z listą sprzętu
- Długoterminowo: Snipe-IT (darmowe)

KONTROLA 3: OCHRONA DANYCH

Co sprawdzamy	Status	Gap	Priorytet
Mamy zasady "co jest POUFNE"?	 BRAK	Nikt nie wie co można wysłać	 KRYTYCZNY
Staging NIE MA danych produkcyjnych?	 BRAK	Staging miał prawdziwe dane!	 KRYTYCZNY

CO POSZŁO ŹŁE:

- Piotr dostał dostęp do staging = dostał prawdziwe dane klientów

Rekomendacja:

- NATYCHMIAST: Usuń prawdziwe dane ze staging
- Stwórz klasyfikację: PUBLICZNE / WEWNĘTRZNE / POUFNE / TAJNE
- DLP (Data Loss Prevention) - wykrywa wycieki

KONTROLA 5: ZARZĄDZANIE KONTAMI

Co sprawdzamy	Status	Gap	Priorytet
Mamy listę wszystkich kont?	 CZĘŚCIOWO	Okta: TAK. AWS: NIE	 KRYTYCZNY
Proces nadawania dostępów?	 BRAK	Marcin dodał Piotra bez approval	 KRYTYCZNY
Regularnie sprawdzamy kto co ma?	 BRAK	Nigdy nie robiliśmy	 KRYTYCZNY

CO POSZŁO ŹŁE:

- Piotr dostał dostęp bez formalnego procesu
- Nikt nie sprawdził po miesiącu "czy nadal potrzebuje"
- Przy zwalnianiu: nie usunęliśmy konta AWS

Rekomendacja:

- NATYCHMIAST: Audyt kont AWS (usuń zombie accounts)
- Proces: Dostęp tylko po zatwierdzeniu managera
- Co 3 miesiące: sprawdzamy kto co ma (access review)

KONTROLA 6: KONTROLA DOSTĘPÓW

Co sprawdzamy	Status	Gap	Priorytet
Minimalne uprawnienia (least privilege)?	 BRAK	Piotr miał dostęp do WSZYSTKIEGO w staging	 KRYTYCZNY
MFA (kod z telefonu) wszędzie?	 CZĘŚCIOWO	Okta: TAK. AWS: NIE	 KRYTYCZNY

CO POSZŁO ŹLE:

- Piotr potrzebował "czytać logi"
- Dostał "pełny dostęp" (w tym hasła do bazy!)

Rekomendacja:

- NATYCHMIAST: Wymuś MFA w AWS
 - Zasada: "Daj minimum, potem dodaj jeśli trzeba"
-

KONTROLA 7: ZARZĄDZANIE PODATNOŚCIAMI

Co sprawdzamy	Status	Gap	Priorytet
Regularnie skanujemy dziury?	 BRAK	Pentest 1x/rok. Między: NIC	 WYSOKI
Naprawiamy znalezione dziury?	 BRAK	2 CRITICAL z maja - NIE naprawione	 KRYTYCZNY

CO POSZŁO ŹLE:

- Maj: Pentest znalazł że staging publicznie dostępny
- Grudzień: NADAL nie naprawione (6 miesięcy!)

Rekomendacja:

- NATYCHMIAST: Napraw 2 CRITICAL
 - Proces: CRITICAL = naprawa w 7 dni
 - AWS Inspector - ciągle skanowanie
-

KONTROLA 8: LOGI

Co sprawdzamy	Status	Gap	Priorytet
Zbieramy logi centralnie?	 BRAK	CloudTrail włączony, nikt nie patrzy	 KRYTYCZNY

Regularnie
przeglądamy?

✗ BRAK Nikt NIGDY nie przegląda

● KRYTYCZNY

CO POSZŁO ŹLE:

- CloudTrail zapisywał WSZYSTKO (logowanie 2AM, pobieranie GB)
- NIKT NIE PATRZYŁ
- Odkryliśmy jak klient zadzwonił

Rekomendacja:

- Szybko: Weekly przegląd logów (ręcznie)
- Średnio: SIEM (Wazuh darmowy LUB użyj własnego produktu!)
- Alerty automatyczne:
 - Logowanie 2-5 AM
 - Masowe pobieranie
 - Tworzenie nowych kont

KONTROLA 10: OCHRONA PRZED WIRUSAMI

Co sprawdzamy	Status	Gap	Priorytet
Antywirus na wszystkich komputerach?	⚠ CZĘŚCIOWO	Są, ale nikt nie zarządza	● WYSOKI
Centralnie zarządzamy?	✗ BRAK	Nie wiemy: kto ma, czy działa	● WYSOKI

Rekomendacja:

- EDR (następna generacja antywirusa):
 - Microsoft Defender for Endpoint (mamy M365)
 - Wykrywa nietypowe zachowania
 - Centralne zarządzanie

KONTROLA 11: KOPIE ZAPASOWE

Co sprawdzamy	Status	Gap	Priorytet
Proces tworzenia backupów?	 CZĘŚCIOWO	Baza: TAK. Serwery: NIE	 WYSOKI
Testujemy odzyskiwanie?	 BRAK	NIGDY nie próbowaliśmy	 KRYTYCZNY
Backupy nie można skasować?	 BRAK	Admin może wszystko skasować	 WYSOKI

Rekomendacja:

- NATYCHMIAST: Test - odzyskaj jedną bazę
- AWS Backup (automatyczne dla EC2)
- Immutable backups (S3 Object Lock)
- Co kwartał: test odzyskiwania

KONTROLA 13: MONITORING SIECI

Co sprawdzamy	Status	Gap	Priorytet
Wykrywamy dziwny ruch?	 BRAK	Piotr uploadował 4GB - nikt nie zauważył	 WYSOKI

Rekomendacja:

- AWS GuardDuty - wykrywa podejrzany ruch
- DLP - wykrywa masowe transfery danych
- Alert: Email gdy ktoś wysła >500MB

KONTROLA 14: SZKOLENIA (IRONIA!)

Co sprawdzamy	Status	Gap	Priorytet
Wszyscy mają szkolenie?	 CZĘŚCIOWO	Onboarding 1h. Potem: NIC	 WYSOKI
Regularne szkolenia?	 BRAK	Nie robimy refresherów	 WYSOKI
Testujemy phishingiem?	 BRAK	Sprzedajemy phishing sims, nie testujemy siebie!	 KRYTYCZNY

IRONIA:

- Sprzedajemy szkolenia awareness
- Nie szkolimy swoich ludzi
- "Szewc bez butów"

Rekomendacja:

- NATYCHMIAST: Użyj WŁASNEGO PRODUKTU!
- Co 3 miesiące: odświeżenie
- Co miesiąc: test phishing

KONTROLA 17: REAGOWANIE NA INCYDENTY

Co sprawdzamy	Status	Gap	Priorytet
Mamy plan co robić przy ataku?	 BRAK	Gdy Piotr ukradł - improwizacja	 KRYTYCZNY
Wyznaczone osoby odpowiedzialne?	 BRAK	Nikt nie wiedział kto prowadzi	 KRYTYCZNY

CO POSZŁO ŹLE:

- Klient dzwoni "wyciek"

- Panika, chaos
- 3 dni szukaliśmy forensics firm

Rekomendacja:

- IR Plan (dokument):
 - Krok 1: Kto dzwoni
 - Krok 2: Jak zawierać szkody
 - Krok 3: Jak zbierać dowody
 - Krok 4: Komunikacja (klienci, UODO)
 - IR Team: CTO (lead), Marcin (tech), CEO (komunikacja)
 - Contact list: Forensics, prawnik, PR
-

PODSUMOWANIE - TOP 12 LUK

● KRYTYCZNE (0-1 miesiąc):

1. **Dane produkcyjne w staging** (CIS 3.3) - NATYCHMIAST usunąć
2. **Brak klasyfikacji danych** (CIS 3.1) - nie wiadomo co POUFNE
3. **Brak MFA w AWS** (CIS 6.2) - włączyć natychmiast
4. **Nikt nie patrzy na logi** (CIS 8.1) - CloudTrail ignorowany
5. **Nie naprawiamy CRITICAL** (CIS 7.2) - 2 z maja otwarte
6. **Brak procesu dostępu** (CIS 5.2) - każdy daje każdemu
7. **Brak access reviews** (CIS 5.3) - nie sprawdzamy kto co ma
8. **Over-permissioning** (CIS 6.1) - za dużo uprawnień
9. **Brak IR Plan** (CIS 17.1) - nie wiemy co robić przy ataku
10. **Brak testowania backupów** (CIS 11.2) - nie wiemy czy działają
11. **Nie testujemy phishingiem** (CIS 14.3) - ironia!
12. **Brak inventory sprzętu** (CIS 1.1) - nie wiemy co mamy

● WYSOKIE (1-3 miesiące):

13. Brak EDR (CIS 10.1)
14. Brak continuous scanning (CIS 7.1)
15. Brak DLP/network monitoring (CIS 13.2)
16. Brak regular trainings (CIS 14.1)

RISK ASSESSMENT - SecureEdge Solutions

CO TO JEST RISK ASSESSMENT?

Risk Assessment = Ocena Ryzyka

Dla każdego zagrożenia sprawdzamy:

- **Prawdopodobieństwo** - Jak łatwo może się zdarzyć? (Niskie/Średnie/Wysokie)
- **Wpływ** - Jak bardzo nas to zrani? (Niski/Średni/Wysoki/Krytyczny)
- **Ryzyko** = Prawdopodobieństwo × Wpływ

Cel: Wiedzieć co naprawiać NAJPIERW (nie możemy naprawić wszystkiego naraz)

METODOLOGIA

Prawdopodobieństwo:

-  **Niskie** - Raz na 3+ lata
-  **Średnie** - Raz na 1-3 lata
-  **Wysokie** - Kilka razy w roku

Wpływ:

-  **Niski** - <10k PLN, <4h przestoju
-  **Średni** - 10-100k PLN, 4-24h przestoju
-  **Wysoki** - 100-500k PLN, 1-7 dni przestoju
-  **Krytyczny** - >500k PLN, >7 dni LUB koniec firmy

TOP 7 RYZYK

RYZYKO #1: Kolejny Insider Threat (Powtórka Piotra)

Scenariusz: Nowy/istniejący pracownik kradnie dane klientów

Prawdopodobieństwo:  WYSOKIE

- Nie naprawiliśmy niczego od incydentu
- Brak background checks
- Brak monitoringu

Wpływ:  KRYTYCZNY

- 500k PLN (forensics, kary, utrata klientów)
- "Drugi raz?!" = możliwy koniec firmy

Ryzyko:    EKSTREMALNE

Powiązane luki:

- Over-permissioning (CIS 6.1)
- Brak access reviews (CIS 5.3)

- Nikt nie patrzy na logi (CIS 8.1)
- Brak DLP (CIS 13.2)

Rekomendacje:

NATYCHMIAST:

- └─ Audyt dostępów - kto ma dostęp do danych klientów
- └─ Usunąć over-privileged accounts
- └─ Podstawowe alerty CloudTrail

0-3 miesiące:

- └─ Background checks dla wszystkich nowych (2k PLN/osoba)
- └─ Access review co 3 miesiące
- └─ Offboarding checklist (20 punktów)
- └─ SIEM z alertami UBA

3-6 miesięcy:

- └─ DLP (Data Loss Prevention)

RYZYKO #2: Ransomware Attack

Scenariusz: Phishing → malware → szyfrowanie serwerów + backupów

Prawdopodobieństwo: 🟡 ŚREDNIE

- Mamy dziury (2 CRITICAL nie załatane)
- Brak EDR
- Ale: jesteśmy mali

Wpływ: ⬛ KRYTYCZNY

- 200-800k PLN (okup + forensics + odbudowa)
- 7-30 dni przestoju = 0 przychodów

Ryzyko: 🔴🔴 BARDZO WYSOKIE

Powiązane luki:

- Brak EDR (CIS 10.1)

- Nie naprawiamy CRITICAL (CIS 7.2)
- Brak immutable backups (CIS 11.3)
- Brak testowania backupów (CIS 11.2)

Rekomendacje:

NATYCHMIAST:

- └─ Napraw 2 CRITICAL z pentestu
- └─ Immutable backups (S3 Object Lock)
- └─ Test restore - sprawdź czy działa!

0-3 miesiące:

- └─ EDR (Microsoft Defender for Endpoint)
- └─ MFA enforcement w AWS
- └─ Phishing simulations (własny produkt!)

RYZYKO #3: Data Breach przez Misconfiguration

Scenariusz: DevOps robi błąd (S3 bucket publiczny) → dane wyciekają publicznie

Prawdopodobieństwo: ● WYSOKIE

- Już się zdarzyło (pentest znalazł)
- Nie naprawiliśmy
- Brak automatycznego skanowania

Wpływ: ● WYSOKI

- 100-300k PLN (RODO kara, utrata klientów)
- "Trzeci wyciek w rok!"

Ryzyko: ●● BARDZO WYSOKIE

Rekomendacje:

NATYCHMIAST:

- └─ Audyt S3 buckets (czy publiczne?)
- └─ Audyt security groups (usuń "0.0.0.0/0")
- └─ AWS Config - włącz

1-3 miesiące:

└─ Infrastructure as Code (Terraform)

└─ AWS Security Hub

RYZYKO #4: Phishing Attack na C-Level

Scenariusz: CEO/CFO/DevOps dostaje spear-phishing → podaje credentials

Prawdopodobieństwo: 🟡 ŚREDNIE

- Już raz kliknęli (kwiecień 2024)
- AWS NIE MA MFA

Wpływ: 🔴 WYSOKI

- 50-200k PLN
- 1-7 dni przestoju

Ryzyko: 🔴 WYSOKIE

Rekomendacje:

NATYCHMIAST:

└─ MFA enforcement AWS

└─ Phishing sim dla C-level

1-3 miesiące:

└─ Microsoft Defender for Office 365 (Plan 2)

└─ Monthly phishing sims

RYZYKO #5: Utrata Kluczowego Pracownika (Marcin)

Scenariusz: Marcin (jedyne DevOps lead) odchodzi/choruje → nikt nie wie jak działa infra

Prawdopodobieństwo: 🟡 ŚREDNIE

- Bus factor = 1
- Startup = ludzie odchodzą

Wpływ: 🔴 WYSOKI

- 100-200k PLN (external help, przestój)
- 7-30 dni chaosu

Ryzyko: ● WYSOKIE

Rekomendacje:

0-3 miesiące:

- └ Dokumentacja infrastruktury (runbooki)
- └ Infrastructure as Code (Terraform)
- └ Zatrudnij drugiego DevOps
- └ Cross-training: Ania uczy się AWS basics

RYZYKO #6: Compliance Violation (RODO/SOC2)

Scenariusz: Audyt RODO/SOC2 - nie przechodzimy

Prawdopodobieństwo: ● WYSOKIE

- Już mamy RODO investigation (Piotr)
- SOC2 deadline: wrzesień 2025 (6 miesięcy!)
- Nie spełniamy wielu wymagań

Wpływ: ● WYSOKI

- 50-200k PLN (kara) + utrata klientów wymagających SOC2
- 2 najwięksi klienci odejdą

Ryzyko: ●● BARDZO WYSOKIE

Rekomendacje:

0-3 miesiące:

- └ SOC2 readiness assessment (external consultant)
- └ Gap remediation plan
- └ RODO compliance review

3-6 miesięcy:

- └ SOC2 Type II audit (wrzesień 2025)

RYZIKO #7: Brak Disaster Recovery

Scenariusz: Pożar datacenter / ransomware usuwa produkcję + backupy → wszystko przepada

Prawdopodobieństwo: ● NISKIE

- AWS Multi-AZ = bardzo rzadkie
- Ale: ransomware może usunąć backupy jeśli nie immutable

Wpływ: ● KRYTYCZNY

- 1M PLN (odbudowa + utracone przychody)
- 30-90 dni odbudowy LUB koniec firmy

Ryzyko: ● ŚREDNIE

Rekomendacje:

0-1 miesiąc:

- └ Test restore (sprawdź czy backup działa!)
- └ Immutable backups (S3 Object Lock)
- └ Offsite backups (inna region)

3-6 miesięcy:

- └ Quarterly DR drill
- └ DR plan document

MATRYCA RYZYK - PRIORYTETYZACJA

#	Ryzyko	Prawdop.	Wpływ	Ryzyko	Priorytet
1	Kolejny Insider Threat	●	●	●●●	#1
2	Ransomware	●	●	●●	#2

3	Misconfiguration Leak	●	●	●●	#3
6	Compliance (RODO/SOC2)	●	●	●●	#3
4	Phishing C-Level	●	●	●	#4
5	Utrata DevOps	●	●	●	#4
7	Total DR	●	●	●	#5

QUICK WINS (0-1 miesiąc, niskie koszty)

1. Napraw 2 CRITICAL z pentestu - 0 PLN, 1 dzień
2. MFA enforcement w AWS - 0 PLN, 2h
3. Audyt kont AWS (usuń zombie) - 0 PLN, 4h
4. Immutable backups - 0 PLN, 1 dzień
5. Test restore bazy - 0 PLN, 2h
6. CloudTrail basic alerts - 0 PLN, 4h
7. Usuń dane ze staging - 0 PLN, 1 dzień
8. Background checks policy - 2k PLN/osoba
9. Offboarding checklist - 0 PLN, 4h
10. Phishing sim (własny produkt!) - 0 PLN, 2h

PODSUMOWANIE

Top 3 ryzyka:

1. ●●● Kolejny Insider Threat
2. ●● Ransomware
3. ●● Misconfiguration / Compliance

Koszt nie działania:

- Kolejny incydent = prawdopodobny koniec firmy
- RODO + utrata klientów = 500k-1M PLN

Koszt działania:

- Quick wins: ~0 PLN (tylko czas)
- Rok 1 (pełny program): ~500k PLN
- **ROI:** Uniknięcie jednego incydentu = zwrot inwestycji

NARZĘDZIA BEZPIECZEŃSTWA - Katalog Rozwiązań

WPROWADZENIE

Dla każdej kontroli CIS mamy **3 opcje**:

1. **Open Source** - Darmowe, ale wymaga czasu na wdrożenie i utrzymanie
2. **Komercyjne** - Płatne, łatwiejsze, wsparcie vendora
3. **Już mamy** - Wykorzystaj co już kupiliśmy (M365, AWS, Okta)

Nasza sytuacja:

- Budget: ~500k PLN na rok 1
- Zespół: 2 osoby IT (Marcin, Ania) + zatrudniamy CISO
- Preferujemy: "Już mamy" > Open Source > Komercyjne

KONTROLA 1 & 2: ASSET & SOFTWARE INVENTORY

Problem: Nie wiemy co mamy (laptopy, serwery, programy)

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
Snipe-IT	Open Source	0 PLN	Darmowy, prosty	Ręczne wprowadzanie danych

Lansweeper	Komercyjny	~15k PLN	Automatyczne skanowanie, discovery	Koszt
AWS Systems Manager Inventory	Już mamy	0 PLN	Dla serwerów AWS, auto-discovery	Tylko AWS, nie laptopy
Jamf (Mac) + Intune (Win)	Komercyjny	~30k PLN	MDM + inventory, zarządzanie urządzeniami	Wymaga wdrożenia

REKOMENDACJA dla nas:

Faza 1 (miesiąc 1-3):

- └─ Snipe-IT (start ręcznie, 0 PLN)
- └─ Excel jako backup/temporary

Faza 2 (miesiąc 3-6):

- └─ Intune (mamy w M365!) + Jamf dla Mac
- └─ Koszt Jamf: ~10k PLN/rok dla 50 Maców

KONTROLA 3: DATA LOSS PREVENTION (DLP)

Problem: Piotr uploadował 4GB danych, nikt nie zauważył

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
Microsoft Purview DLP	Już mamy (E5)	+80k PLN upgrade	Integracja z M365, OneDrive, email	Wymaga E5 (obecnie E3)

Forcepoint DLP	Komercyjne	~100k PLN	Enterprise-grade, endpoint + network	Drogi, złożony
OpenDLP	Open Source	0 PLN	Darmowy	Wymaga dużo pracy, outdated
AWS Macie	Już mamy	~5k PLN	Skanuje S3, wykrywa PII	Tylko S3, nie endpoint

Faza 1 (miesiąc 1-3):

- └─ AWS Macie - skanuj S3 buckets (~5k PLN/rok)
- └─ Email alerts dla transferów >500MB (CloudWatch, 0 PLN)

Faza 2 (miesiąc 6-12):

- └─ Microsoft 365 E5 upgrade (~80k PLN/rok)
- └─ Dostajemy: DLP, Advanced Threat Protection, więcej

KONTROLA 5 & 6: IDENTITY & ACCESS MANAGEMENT

Problem: Za dużo uprawnień, brak kontroli kto co ma

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
Okta (już mamy)	Już mamy	~50k PLN	SSO, MFA, lifecycle management	Nie pokrywa AWS dobrze
AWS IAM Identity Center	Już mamy	0 PLN	Zarządza AWS accounts, SSO	Tylko AWS

JumpCloud	Komercyjne	~30k PLN	Directory + SSO + MFA, cross-platform	Koszt
FreeIPA	Open Source	0 PLN	LDAP + Kerberos, Linux-native	Wymaga utrzymania

Privileged Access Management (PAM):

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
HashiCorp Vault	Open Source/Komercyjne	0-50k PLN	Secrets management, dynamic credentials	Wymaga wdrożenia
AWS Secrets Manager	Już mamy	~2k PLN	Łatwy, integracja z AWS	Tylko dla AWS secrets
CyberArk	Enterprise	>200k PLN	Enterprise PAM	Za drogi dla nas

REKOMENDACJA dla nas:

Faza 1 (miesiąc 1):

- └─ AWS IAM Identity Center - zarządzanie AWS (0 PLN)
- └─ Okta - kontynuuj dla SaaS apps (już płacimy)
- └─ AWS Secrets Manager - dla DB passwords (~2k PLN)

Faza 2 (miesiąc 3-6):

- └─ Okta Workflows - automatyzacja lifecycle
(onboarding/offboarding, ~10k PLN add-on)

KONTROLA 7: VULNERABILITY MANAGEMENT

Problem: Pentest 1x/rok, nie naprawiamy findings

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
AWS Inspector	Już mamy	~8k PLN	Automatyczne, continuous scanning EC2	Tylko AWS
OpenVAS / Greenbone	Open Source	0 PLN	Darmowy, comprehensive	Wymaga utrzymania serwera
Qualys VMDR	Komercyjne	~60k PLN	Enterprise-grade, cloud + on-prem	Drogi
Tenable Nessus	Komercyjne	~30k PLN	Popularny, dobry	Wymaga dedykowanej osoby
Dependabot (GitHub)	Już mamy	0 PLN	Skanuje kod, dependencies	Tylko kod

Patch Management:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
AWS Systems Manager Patch Manager	Już mamy	0 PLN	Automatyczne patching EC2	Tylko AWS

Intune (Windows)	Już mamy (M365)	0 PLN	Windows Update management	Tylko Windows
-------------------------	-----------------	-------	---------------------------	---------------

REKOMENDACJA dla nas:

Faza 1 (miesiąc 1-3):

- └─ AWS Inspector - EC2 scanning (~8k PLN/rok)
- └─ Dependabot - kod (już mamy, 0 PLN)
- └─ AWS Systems Manager - patch management (0 PLN)
- └─ SLA: CRITICAL 7 dni, HIGH 30 dni

Faza 2 (miesiąc 6-12):

- └─ Tenable Nessus (jeśli potrzeba głębszych testów, ~30k PLN)

KONTROLA 8: AUDIT LOG MANAGEMENT (SIEM)

Problem: CloudTrail zapisuje, nikt nie patrzy

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
NASZ WŁASNY SIEM!	Już mamy	0 PLN	IRONIA: sprzedajemy go!	Musimy go skonfigurować dla nas
Wazuh	Open Source	0-10k PLN	Darmowy, SIEM + EDR, dobre community	Wymaga wdrożenia (1-2 mies)

AWS Security Hub + GuardDuty	Już mamy	~20k PLN	Natywna integracja AWS, łatwe	Tylko AWS, nie on-prem
Splunk	Komercyjne	>100k PLN	Najlepszy SIEM, ale...	ZA DROGI
Microsoft Sentinel	Komercyjne	~60k PLN	Integracja M365 + Azure	Wymaga Azure, data ingestion costs
ELK Stack	Open Source	0-20k PLN	Darmowy (Elasticsearch, Logstash, Kibana)	Wymaga utrzymania

REKOMENDACJA dla nas (NAJWAŻNIEJSZA DECYZJA!):

OPCJA A - "Eat our own dog food" (POLECAM):

- └─ Użyj NASZEGO własnego produktu SIEM
- └─ Koszt: 0 PLN (już mamy)
- └─ Benefit: Pokazujemy klientom że ufamy własnemu produktowi
- └─ Marketing: "Używamy tego co sprzedajemy"
- └─ Czas: 2-3 tygodnie konfiguracji (Marcin + 1 dev)
- └─ Risk: Jeśli nasz produkt słaby - będzie widać

OPCJA B - Hybrid (bardziej realistyczna):

- └─ AWS Security Hub + GuardDuty (~20k PLN)
 - └─ Dla infrastruktury AWS
- └─ + Wazuh dla endpoints (laptopy, 0 PLN)
- └─ Czas: 1 miesiąc wdrożenia

Quick Win (tydzień 1):

└─ CloudWatch Alerts + SNS (email alerts)

└─ Alert: Logowanie 2-5 AM

└─ Alert: Failed login attempts >5

└─ Alert: IAM changes

└─ Koszt: 0 PLN, Czas: 4 godziny

KONTROLA 10: MALWARE DEFENSES (EDR)

Problem: Brak centralnego antywirusa, każdy laptop inny

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
Microsoft Defender for Endpoint	Już mamy (w M365 E5)	+80k PLN upgrade	Integracja M365, centralne zarządzanie	Wymaga E5
CrowdStrike Falcon	Komercyjne	~60k PLN	Top-tier EDR, najlepsze wykrywanie	Drogi
SentinelOne	Komercyjne	~50k PLN	AI-driven, dobry	Wymaga wdrożenia
Wazuh	Open Source	0 PLN	SIEM + EDR w jednym	Słabszy niż komercyjne EDR
Intune + Windows Defender	Już mamy (M365 E3)	0 PLN	Zarządzanie Windows Defender	Basic, nie full EDR

REKOMENDACJA dla nas:

Faza 1 (miesiąc 1-2):

- └─ Intune + managed Windows Defender (0 PLN)
- └─ Wykorzystaj co już mamy w M365 E3
- └─ Centralne zarządzanie, podstawowa ochrona

Faza 2 (miesiąc 6-9, jeśli budżet):

- └─ Microsoft 365 E5 upgrade (~80k PLN/rok)
- └─ Dostajemy: Defender for Endpoint (full EDR) + DLP + ATP

LUB jeśli nie E5:

- └─ CrowdStrike Falcon (~60k PLN/rok)
- └─ Lepsze wykrywanie niż Defender

KONTROLA 11: DATA RECOVERY (BACKUP)

Problem: Nie testujemy backupów, nie immutable

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
AWS Backup	Już mamy	~10k PLN	Centralne zarządzanie, policy-based	Tylko AWS
Veeam Backup for AWS	Komercyjny	~20k PLN	Enterprise backup, immutable	Koszt
Restic + S3	Open Source	~3k PLN (storage)	Darmowy, encryption, dedup	Wymaga skryptów

Synology Active Backup	Już mamy	0 PLN	Dla laptopów/fizycznych	Tylko local/NAS
-----------------------------------	----------	-------	-------------------------	--------------------

REKOMENDACJA dla nas:

Faza 1 (miesiąc 1):

- └ AWS Backup - policy dla EC2, RDS (~10k PLN/rok)
- └ S3 Object Lock - immutable backups (0 PLN, feature)
- └ Test restore - NATYCHMIAST sprawdź (0 PLN, 2h)
- └ Synology - backupy laptopów do NAS (już mamy)

Faza 2 (miesiąc 3):

- └ Quarterly DR drill (symulacja disaster recovery)
- └ Multi-region backups (S3 replication, ~5k PLN/rok)
- └ Documented RTO/RPO

KONTROLA 14: SECURITY AWARENESS TRAINING

Problem: Nie szkolimy regularnie, nie testujemy phishingiem

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
NASZ WŁASNY PRODUKT!	Już mamy	0 PLN	IRONIA: sprzedajemy szkolenia!	Musimy go użyć dla siebie
KnowBe4	Komercyjne	~25k PLN	Największy vendor, dobre treści	Koszt

SANS Security Awareness	Komercyjne	~30k PLN	Najlepsze treści, ale...	Drogi
PhishMe / Cofense	Komercyjne	~20k PLN	Phishing simulations, reportowanie	Tylko phishing, nie full training

REKOMENDACJA dla nas (OCZYWISTE!):

UŻYJ WŁASNEGO PRODUKTU! (0 PLN)

Implementacja:

- └─ Onboarding: 1h training (już robimy)
- └─ Quarterly refresh: Co 3 miesiące (15 min webinar)
- └─ Monthly phishing sim: Nasz phishing engine
- └─ Metryki:
 - | └─ % ukończonych trainings (cel: >95%)
 - | └─ % klikających phishing (cel: <5%)
 - | └─ Czas zgłoszenia phishingu (cel: <1h)
 - └─ Benefit: Marketing! "Używamy naszego produktu"

KONTROLA 17: INCIDENT RESPONSE

Problem: Brak planu, nie wiemy co robić przy ataku

Opcje:

Narzędzie	Typ	Koszt/rok	Plusy	Minusy
TheHive + Cortex	Open Source	0 PLN	Case management, automation	Wymaga wdrożenia

ServiceNow Security Operations	Komercyjne	>100k PLN	Enterprise SOAR, ale...	ZA DROGI
Jira Service Management	Już mamy	+5k PLN	Ticketing dla incidents, już znamy	Nie dedykowany dla security
PagerDuty	Komercyjne	~15k PLN	Incident alerting, on-call	Tylko alerting, nie case mgmt

Forensics Retainer:

Firma	Koszt/rok	Co daje
SecureWorks Polska	10-20k PLN	Priorytetowy dostęp, 4h response time
KPMG Cyber	15-30k PLN	Big4, drożej ale prestiż
Ad-hoc (bez retainer)	0 PLN teraz, 60k+ gdy incydent	Tańsze teraz, droższe później

REKOMENDACJA dla nas:

Faza 1 (miesiąc 1):

- └ IR Plan (dokument, szablon z NIST/SANS, 0 PLN)
- └ IR Team wyznaczony (CISO lead, Marcin tech, CEO comm)
- └ Contact list (forensics, prawnik, PR)
- └ Runbook: "Co robić krok po kroku"

Faza 2 (miesiąc 2-3):

- └─ Jira dla incident tracking (+5k PLN/rok)
- └─ Tabletop exercise (2h warsztat, external facilitator ~5k PLN)
- └─ Retainer z SecureWorks (~15k PLN/rok)

Faza 3 (miesiąc 6):

- └─ TheHive (open source SOAR, 0 PLN jeśli mamy czas wdrożyć)

PODSUMOWANIE KOSZTÓW - ROK 1

Już mamy / Wykorzystaj lepiej:

- └─ Okta (kontynuacja, już płacimy)
- └─ M365 E3 (kontynuacja, już płacimy)
- └─ AWS native tools (Inspector, Backup, Systems Manager)
- └─ Własny produkt SIEM
- └─ Własny produkt Training & Phishing
- └─ Snipe-IT (inventory)

Nowe wydatki:

- └─ AWS Inspector + GuardDuty: ~20k PLN
- └─ Jamf (Mac MDM): ~10k PLN
- └─ AWS Backup (storage costs): ~10k PLN
- └─ HashiCorp Vault / Secrets Manager: ~5k PLN
- └─ IR retainer (SecureWorks): ~15k PLN
- └─ SOC2 consultant + audit: ~80k PLN
- └─ Misc (trainings, tools): ~10k PLN
- └─ Microsoft 365 E5 upgrade: +80k PLN
- | └─ Dostajemy: DLP, Defender for Endpoint (EDR), ATP
- └─ Tenable Nessus (vuln scanning): ~30k PLN

└─ CrowdStrike Falcon (jeśli nie E5 EDR): ~60k PLN

└─ Drugi DevOps hire: ~200k PLN/rok

└─ TOTAL: ~300k PLN

+ CISO: ~250k PLN

= GRAND TOTAL: ~700k PLN rok 1

PLAN WDROŻENIA - SecureEdge Solutions

JAK TO BĘDZIE WYGLĄDAĆ

Plan podzielony na **3 fazy**:

Faza 1 (0-3 miesiące) = Szybkie wygrane - napraw co pali się TERAZ

Faza 2 (3-9 miesięcy) = Główne projekty - zbuduj fundament

Faza 3 (9-18 miesięcy) = Dojrzałość - doskonalenie i optymalizacja

FAZA 1: SZYBKIE WYGRANE (0-3 MIESIĄCE)

Cel: Napraw najgorsze dziury, nie daj się zhakować ponownie

TYDZIEŃ 1 (NATYCHMIASTOWE DZIAŁANIA)

1. Napraw 2 CRITICAL z pentestu

Co robimy:

└─ Staging environment: Usuń publiczny dostęp, dodaj hasło

└─ S3 bucket: Zmień z "public" na "private"

└─ Stare klucze SSH: Usuń wszystkie 12 nieużywanych

Kto: Marcin (DevOps)

Czas: 1 dzień

Koszt: 0 PLN

2. Usuń prawdziwe dane ze staging

Co robimy:

- └ Skopiuj TYLKO syntetyczne/anonimizowane dane do staging DB

Kto: Marcin + 1 developer

Czas: 2 dni

Koszt: 0 PLN

3. Włącz MFA w AWS (WSZYSTKIE konta)

Co robimy:

- └ Policy: Każdy MUSI mieć MFA żeby się zalogować do AWS
- └ Daj ludziom 48h deadline
- └ Po 48h: Konta bez MFA = zablokowane

Kto: Marcin

Czas: 2 godziny setup + 2 dni na adoption

Koszt: 0 PLN

4. Audyt kont AWS - usuń zombie accounts

Co robimy:

- └ Lista wszystkich user accounts w AWS
- └ Sprawdź kto pracuje, kto nie
- └ Usuń konta byłych pracowników
- └ Usuń konta "testowe" utworzone i zapomniane

Kto: Marcin + Ania

Czas: 4 godziny

Koszt: 0 PLN

Rezultat: Znaleźliśmy i usunęliśmy 23 konta (w tym Piotr!)

TYDZIEŃ 2-4

5. Podstawowe alerty CloudTrail

Co robimy:

Ustaw alerty które wysyłają EMAIL gdy:

- |— Ktoś loguje się 2-5 AM
- |— Ktoś próbuje 5+ razy złego hasła
- |— Ktoś tworzy nowe konto IAM
- |— Ktoś zmienia security groups
- |— Ktoś pobiera >500MB z S3 naraz

Narzędzie: AWS CloudWatch + SNS (już mamy, 0 PLN)

Kto: Marcin

Czas: 4 godziny

Koszt: 0 PLN

6. Immutable backups (nie można skasować)

Co robimy:

- |— Włącz S3 Object Lock na bucketach z backupami
 - |— Backup nie może być usunięty przez 30 dni (nawet przez admina)

Dlaczego: Ransomware nie może skasować backupów

Kto: Marcin

Czas: 1 dzień

Koszt: 0 PLN

7. TEST RESTORE - sprawdź czy backup działa!

Co robimy:

- └ Weź snapshot bazy danych sprzed tygodnia
- └ Odtwórz go na testowym serwerze
- └ Sprawdź czy działa
- └ Dokumentuj: Ile czasu zajęło? Co poszło nie tak?

Dlaczego: Nie wiemy czy backup działa dopóki nie spróbujemy

Kto: Marcin

Czas: 2 godziny

Koszt: 0 PLN

8. Offboarding checklist (20 punktów)

Co robimy:

Stwórz checklist dla HR - co zrobić gdy ktoś odchodzi:

- ☐ Odbierz laptop
- ☐ Odbierz kartę dostępu
- ☐ Wyłącz Okta
- ☐ Wyłącz AWS IAM user
- ☐ Sprawdź czy nie utworzył innych kont AWS
- ☐ Wyłącz Tailscale VPN
- ☐ Usuń z GitHub organizacji
- ☐ Usuń z Slack (lub archive)

- ☐ Zmień hasła które znał (DB, services)
- ☐ Sprawdź AWS CloudTrail - co robił ostatnie 2 tygodnie
- ... (+ 10 więcej)

Kto: Ania (IT Support) + HR

Czas: 4 godziny stworzenia checklisty

Koszt: 0 PLN

9. Background checks - nowa polityka

Co robimy:

- └─ Od teraz: KAŻDY nowy pracownik = background check
- └─ Koszt: 2,000 PLN/osoba (warto!)
- └─ Vendor: Sprawdzamy historię zatrudnienia, edukację, criminal record

Dlaczego: Piotr prawdopodobnie był "fake identity"

Kto: HR

Czas: 1 dzień setup z vendorem

Koszt: 2k PLN per hire (ongoing)

Co robimy:

- └─ Od teraz: KAŻDY nowy pracownik = background check
- └─ Koszt: 2,000 PLN/osoba (warto!)
- └─ Vendor: Sprawdzamy historię zatrudnienia, edukację, criminal record

Dlaczego: Piotr prawdopodobnie był "fake identity"

Kto: HR

Czas: 1 dzień setup z vendorem

Koszt: 2k PLN per hire (ongoing)

10. Spis sprzętu - start (Snipe-IT)

Co robimy:

- | — Zainstaluj Snipe-IT (darmowy, open source)
- | — Wprowadź wszystkie laptopy ręcznie:
 - | | — Laptop #001: MacBook Pro, Serial ABC123, User: Jan Kowalski
 - | | — Laptop #002: Dell Latitude, Serial XYZ789, User: Anna Nowak
 - | | — ... (105 laptopów)
- | — Proces: Przy daniu nowego laptopa → wpis do Snipe-IT

Kto: Ania (IT Support)

Czas: 1 tydzień (ręczne wprowadzanie)

Koszt: 0 PLN

MIESIĄC 2-3

11. Użyj WŁASNEGO produktu - Training & Phishing!

Co robimy:

- | — Wszyscy pracownicy: Zapiszemy na własną platformę szkoleniową
- | — Quarterly training: Co 3 miesiące odświeżenie (15 min)
- | — Monthly phishing sim: Raz w miesiącu test email
- | — Metryki: Kto kliknął, kto zgłosił

Dlaczego: "Szewc bez butów" - używamy co sprzedajemy!

Kto: Zespół contentu (setup) + Wszyscy (szkolenie)

Czas: 1 tydzień setup, 15 min/osoba/kwartał

Koszt: 0 PLN (nasz produkt!)

Marketing benefit: "Używamy naszego produktu wewnętrznie!"

12. Klasyfikacja danych - policy

Co robimy:

Stwórz zasady "co jest POUFNE":

PUBLICZNE:

└ Marketing, strona www, blog posty

WEWNĘTRZNE:

└ Dokumentacja, slajdy, notatki ze spotkań

POUFNE:

└ Kontrakty z klientami, wyniki phishing sims, listy kontaktów

ŚCIŚLE TAJNE:

└ Kod źródłowy, dane klientów (PII), financial data

Instrukcja dla pracowników:

└ Oznaczaj dokumenty: [POUFNE] w nazwie pliku

└ ŚCIŚLE TAJNE nigdy email, tylko przez secure share

└ Pytaj jeśli nie wiesz

Kto: CISO (jak przyjdzie) + Legal

Czas: 1 tydzień

Koszt: 0 PLN

13. AWS Inspector + GuardDuty

Co robimy:

- |— Włącz AWS Inspector: Skanuje EC2 szukając podatności
- |— Włącz AWS GuardDuty: Wykrywa dziwny ruch sieciowy
- └ Email alerts gdy znajdzie coś CRITICAL

Kto: Marcin

Czas: 1 dzień

Koszt: ~20k PLN/rok

14. Incident Response Plan (dokument)

Co robimy:

Napisz plan "Co robić jak będzie atak":

KROK 1: WYKRYCIE

- └ Kto dzwoni: CISO → CTO → CEO

KROK 2: CONTAINMENT (powstrzymanie)

- |— Odłącz zhakowany serwer od sieci
- |— Zmień wszystkie hasła
- └ Zablokuj konta podejrzanych userów

KROK 3: FORENSICS (śledztwo)

- |— Zadzwoń: SecureWorks (tel: XXX-XXX-XXX)
- |— NIE kasuj niczego (dowody!)
- └ Zbierz logi

KROK 4: KOMUNIKACJA

- |— Wewnętrzna: CEO mail do zespołu
- |— Klienci: Email do dotkniętych (szablon gotowy)
- |— UODO: Notification w 72h (szablon gotowy)
- └ Prasa: Przez PR firm (kontakt: YYY-YYY-YYY)

KROK 5: RECOVERY

- └ Odtwórz z backupów, napraw dziurę, wróć online

IR Team:

- |— Lead: CISO
- |— Tech: Marcin (DevOps)
- |— Communication: CEO
- └ Legal: Prawnik (external, tel: ZZZ-ZZZ-ZZZ)

Kto: CISO + CTO

Czas: 1 tydzień pisania

Koszt: 0 PLN

15. SOC2 readiness assessment

Co robimy:

- |— Zatrudnij konsultanta SOC2
- |— Gap analysis: Co mamy, czego brakuje do SOC2
- |— Plan naprawczy: Lista 50 rzeczy do zrobienia
- └ Deadline: Wrzesień 2025

Kto: External consultant

Czas: 2 tygodnie

Koszt: ~30k PLN (część budżetu SOC2)

REZULTAT FAZY 1 (po 3 miesiącach):

- ✓ 2 CRITICAL załatane
- ✓ Staging bez danych produkcyjnych
- ✓ MFA wszędzie
- ✓ Zombie accounts usunięte
- ✓ Podstawowe alerty działają
- ✓ Backupy immutable i przetestowane
- ✓ Offboarding checklist działa
- ✓ Background checks policy
- ✓ Spis sprzętu started
- ✓ Własny produkt używany wewnętrznie
- ✓ Klasyfikacja danych
- ✓ AWS Inspector działa
- ✓ IR Plan gotowy
- ✓ SOC2 plan gotowy

Koszt Faza 1: ~50k PLN

Największe ryzyka zmniejszone: Insider Threat (50%), Ransomware (30%), Misconfiguration (60%)

FAZA 2: GŁÓWNE PROJEKTY (3-9 MIESIĘCY)

Cel: Zbuduj solidny fundament security

MIESIĄC 4-6

16. Zatrudnij CISO

Co robimy:

- └ Rekrutacja (2 miesiące)
- └ Onboarding (1 miesiąc)
- └ CISO przejmuje prowadzenie projektu od Ciebie

Profil:

- └ 5+ lat doświadczenia security

- └─ Doświadczenie SOC2/ISO compliance

- └─ Startup mindset (nie korporacja)

- └─ Wynagrodzenie: ~250k PLN/rok

Kto: CEO + HR

Czas: 2-3 miesiące rekrutacja

Koszt: ~250k PLN/rok

17. Microsoft 365 E5 upgrade

Co robimy:

Upgrade z E3 → E5 (100 licencji)

Co dostajemy:

- └─ DLP (Data Loss Prevention) - wykrywa wycieki

- └─ Defender for Endpoint (EDR) - zaawansowany antywirus

- └─ Advanced Threat Protection - lepsza ochrona email

- └─ Cloud App Security

- └─ Compliance tools

Dlaczego warto:

- └─ Jedna płatność, wszystko w jednym miejscu

Kto: Marcin + Microsoft account manager

Czas: 1 miesiąc wdrożenia

Koszt: +80k PLN/rok (różnica E3→E5)

18. DLP - wdrożenie (Microsoft Purview)

Co robimy (po E5 upgrade):

- | — Skanuj OneDrive, email, Slack szukając:
 - | | — Numery PESEL, karty kredytowe
 - | | — Hasła (strings jak "password: xxx")
 - | | — Pliki oznaczone [POUFNE]
- | — Policy: Blokuj wysyłanie POUFNE poza firmę
- | — Alert: Email do CISO gdy ktoś próbuje

Kto: CISO + Marcin

Czas: 1 miesiąc konfiguracji

Koszt: 0 PLN (w E5)

19. EDR - wdrożenie (Defender for Endpoint)

Co robimy (po E5 upgrade):

- | — Zainstaluj agent na wszystkich laptopach (auto przez Intune)
- | — Centralne zarządzanie antywirusem
- | — Wykrywanie dziwnych zachowań:
 - | | — Ransomware encryption
 - | | — Credential dumping
 - | | — Lateral movement
- | — Automatic isolation: Laptop podejrzany = odcięty od sieci

Kto: Marcin + Ania

Czas: 2 tygodnie deployment

Koszt: 0 PLN (w E5)

20. SIEM - własny produkt wdrożony

Co robimy:

- | — Użyj NASZEGO SIEM produktu dla wewnętrznej infrastruktury

- └─ Połącz źródła logów:
 - | └─ AWS CloudTrail
 - | └─ AWS GuardDuty
 - | └─ Microsoft 365 logs
 - | └─ Okta logs
 - | └─ GitHub audit logs
- └─ Reguły wykrywania:
 - | └─ Logowanie nocne (2-5 AM)
 - | └─ Failed logins >5
 - | └─ Masowe pobieranie danych
 - | └─ Tworzenie nowych kont
 - | └─ Zmiany uprawnień
- └─ Dashboard: CISO widzi wszystko w jednym miejscu

Kto: 2 developerów + Marcin

Czas: 1 miesiąc konfiguracji

Koszt: 0 PLN (nasz produkt!)

Marketing: "Używamy własnego SIEM wewnątrz - case study!"

21. Access Review - proces kwartalny

Co robimy:

Co 3 miesiące:

- └─ CISO wysła email do każdego managera:
 - | "Twoi ludzie mają te dostępy. Czy nadal potrzebują?"
- └─ Manager przegląda i odpowiada
- └─ IT usuwa niepotrzebne dostępy

└ Raport: Ile dostępów usunięto

Automatyzacja (opcjonalna):

└ Okta Workflows - automatycznie generuje listę

Kto: CISO + Managerowie

Czas: 4h/kwartał (recurring)

Koszt: 0 PLN (lub +10k PLN Okta Workflows)

22. Zatrudnij drugiego DevOps

Co robimy:

└ Rekrutacja Mid-level DevOps

└ Backup dla Marcina (bus factor = 2, nie 1)

└ Focus: Security + Infrastructure as Code

Profil:

└ 2-3 lata DevOps

└ AWS certified

└ Terraform experience

└ Wynagrodzenie: ~180k PLN/rok

Kto: CEO + Marcin

Czas: 2 miesiące rekrutacja

Koszt: ~180k PLN/rok

MIESIĄC 7-9

23. Infrastructure as Code (Terraform)

Co robimy:

- |— Cała infrastruktura AWS opisana w kodzie (Terraform)
- |— Korzyści:
 - | |— Dokumentacja: Kod = dokumentacja jak działa infra
 - | |— Reprodukowalność: Możemy odtworzyć wszystko z kodu
 - | |— Review: Zmiany infrastruktury = code review (jak zwykły kod)
 - | |— Security scanning: tfsec skanuje kod przed deployment
- |— Proces: Żadnych zmian "ręcznie", wszystko przez Terraform

Kto: Marcin + nowy DevOps

Czas: 3 miesiące (migracja istniejącej infra do kodu)

Koszt: 0 PLN (Terraform open source)

24. AWS Backup - automated

Co robimy:

- |— Policy: Wszystkie EC2, RDS = automatic backup
- |— Schedule:
 - | |— Production DB: Daily, retention 30 days
 - | |— Production EC2: Weekly, retention 90 days
 - | |— Staging: Weekly, retention 7 days
- |— Multi-region: Kopie w eu-west-1 (backup dla backup)
- |— Monthly test: Odtwórz random backup

Kto: Nowy DevOps

Czas: 2 tygodnie

Koszt: ~15k PLN/rok (storage)

25. Vulnerability Management - continuous

Co robimy:

- |— AWS Inspector: Już działa (Faza 1)
- |— Tenable Nessus: Dodatkowo dla głębszych skanów
- |— SLA (Service Level Agreement):
 - | |— CRITICAL: Naprawa w 7 dni
 - | |— HIGH: Naprawa w 30 dni
 - | |— MEDIUM: Naprawa w 90 dni
 - | |— LOW: Backlog
- |— Monthly report: CISO → CTO → Zarząd

Kto: CISO + DevOps team

Czas: Ongoing

Koszt: ~30k PLN/rok (Nessus)

26. SOC2 Type II Audit

Co robimy:

- |— 3-miesięczny audit (czerwiec-sierpień)
- |— Audytor sprawdza:
 - | |— Czy mamy wszystkie kontrolki
 - | |— Czy działają (przez 3 miesiące)
 - | |— Dokumentacja
- |— Raport SOC2 Type II
- |— Certyfikat (ważny 12 miesięcy)

Kto: External auditor + CISO

Czas: 3 miesiące

Koszt: ~80k PLN (audyt + konsultant)

Deadline: Wrzesień 2025

REZULTAT FAZY 2 (po 9 miesiącach):

- ✓ CISO zatrudniony
- ✓ M365 E5 (DLP + EDR)
- ✓ Własny SIEM działa
- ✓ Drugi DevOps
- ✓ Infrastructure as Code
- ✓ Automated backups
- ✓ Continuous vuln scanning
- ✓ SOC2 certified
- ✓ Quarterly access reviews

Koszt Faza 2: ~450k PLN

Headcount: +2 (CISO, DevOps)

Compliance: SOC2 ✓

FAZA 3: DOJRZAŁOŚĆ (9-18 MIESIĘCY)

Cel: Doskonalenie, optymalizacja, zaawansowane funkcje

MIESIĄC 10-12

27. PAM - Privileged Access Management

Co robimy:

- └ HashiCorp Vault dla secrets (hasła, API keys)
- └ Dynamic credentials: Hasła rotują się automatycznie
- └ Just-In-Time access: Admin na 4h, potem wygasa
- └ Audit: Kto kiedy użył jakiego hasła

Kto: DevOps team + CISO

Czas: 2 miesiące

Koszt: ~20k PLN/rok

28. Network segmentation - micro

Co robimy:

- └ AWS VPC: Więcej podziałów
- | └ Web tier (tylko ALB)

- | └─ App tier (EC2 aplikacyjne)
- | └─ Data tier (RDS, tylko z app tier)
- | └─ Management (bastion, monitoring)
- └─ Security Groups: Strict rules między tierami
- └─ Principle: Minimalna komunikacja

Kto: DevOps team

Czas: 1 miesiąc

Koszt: 0 PLN

29. Tabletop Exercises - quarterly

Co robimy:

Co kwartał 2h warsztat:

- └─ Scenariusz: "Ransomware zahakował production"
- └─ Team: CISO, CTO, CEO, DevOps, Legal
- └─ Dyskusja: Co robimy krok po kroku?
- └─ Notatki: Co poszło źle, co poprawić
- └─ Update IR Plan

Kto: CISO (facilitator)

Czas: 2h/kwartał (recurring)

Koszt: 0 PLN

30. Bug Bounty Program - pilot

Co robimy:

- └─ Platform: HackerOne lub Bugcrowd
- └─ Scope: Nasza platforma szkoleniowa (produkcja)
- └─ Nagrody:

- | └─ CRITICAL: 5,000 PLN
- | └─ HIGH: 2,000 PLN
- | └─ MEDIUM: 500 PLN
- | └─ LOW: 200 PLN
- └─ Budget cap: 30k PLN/rok
- └─ Process: Bug report → verify → fix → pay

Dlaczego: Continuous pentesting przez community

Kto: CISO + Engineering

Czas: 1 miesiąc setup

Koszt: ~30k PLN/rok (bounties)

MIESIĄC 13-18

31. ISO 27001 preparation

Co robimy:

- └─ Mamy już SOC2 (90% overlap z ISO)
- └─ Gap analysis: Co dodatkowo potrzebne
- └─ Dokumentacja (polityki, procedury)
- └─ Internal audit (6 miesięcy)
- └─ Certification audit

Dlaczego: Klienci enterprise wymagają

Kto: CISO + External consultant

Czas: 6-12 miesięcy

Koszt: ~100k PLN (konsultant + audyt)

Deadline: Q4 2026

32. Security Champions Program

Co robimy:

- | — 1 osoba w każdym dziale = Security Champion
- | — Rola:
 - | | — Ambasador security w dziale
 - | | — Odpowiada na pytania zespołu
 - | | — Reprezentuje dział w security meetings
- | — Training: Miesięczne sesje z CISO
- | — Incentive: Bonus roczny 2k PLN

Kto: CISO

Czas: 2 miesiące setup

Koszt: ~20k PLN/rok (bonusy)

33. Metrics & Reporting - dashboard

Co robimy:

Dashboard dla zarządu (Grafana):

- | — Security posture:
 - | | — % laptopów z EDR
 - | | — % otwartych CRITICAL vulnerabilities
 - | | — Średni czas naprawy (MTTR)
 - | | — Compliance score (SOC2, ISO)
- | — Awareness:
 - | | — % ukończonych trainings
 - | | — Phishing click rate (cel: <5%)
 - | | — Incidents reported

└ Operations:

| └ # incydentów/miesiąc

| └ Czas reakcji

| └ Backup success rate

└ Monthly report dla zarządu (1 slajd)

Kto: CISO + DevOps

Czas: 1 miesiąc

Koszt: 0 PLN

REZULTAT FAZY 3 (po 18 miesiącach):

- ✓ PAM wdrożone
- ✓ Network micro-segmentation
- ✓ Quarterly tabletop exercises
- ✓ Bug bounty działa
- ✓ ISO 27001 w toku
- ✓ Security Champions
- ✓ Metrics dashboard

Koszt Faza 3: ~200k PLN

Maturity level: High (4/5)

TIMELINE - GANTT CHART (uproszczony)

M1 M2 M3 M4 M5 M6 M7 M8 M9 M10 M11 M12 M13-18

FAZA 1

└ Quick fixes

└ Policies

└ Basic tools

└ IR Plan

FAZA 2

└ Hiring

└─E5 upgrade	██████████
└─SIEM	██████████████
└─IaC	██████████
└─SOC2	██████████████

FAZA 3	████████████████████
└─PAM	██████████
└─ISO prep	██████████████
└─Optimization	██████████████

BUDŻET - PODSUMOWANIE

Rok 1 (18 miesięcy projektu):

OPEX (Operational Expenses):

Headcount:

└─ CISO: 250k PLN/rok
└─ DevOps #2: 180k PLN/rok
└─ Subtotal: 430k PLN/rok

Software & Services:

└─ M365 E5 upgrade: +80k PLN/rok
└─ AWS security tools (Inspector, GuardDuty, Backup): 35k PLN/rok
└─ Jamf (Mac MDM): 10k PLN/rok
└─ Tenable Nessus: 30k PLN/rok
└─ HashiCorp Vault: 20k PLN/rok
└─ Bug bounty: 30k PLN/rok
└─ IR retainer: 15k PLN/rok
└─ Subtotal: 220k PLN/rok

One-time:

- └─ SOC2 audit + consultant: 80k PLN
- └─ Background checks (10 hires × 2k): 20k PLN
- └─ Training/workshops: 10k PLN
- └─ Subtotal: 110k PLN

TOTAL ROK 1: ~760k PLN

OPEX ongoing: ~650k PLN/rok (headcount + tools)

+ ISO 27001: ~100k PLN

= TOTAL ROK 2: ~750k PLN

METRYKI SUKCESU

Jak zmierzemy czy projekt się powiodł:

Techniczne (CISO → CTO):

- └─ 100% laptopów z EDR (cel: koniec M6)
- └─ 0 otwartych CRITICAL vulnerabilities >30 dni (cel: koniec M9)
- └─ 100% backupów tested quarterly (cel: koniec M3)
- └─ <1h mean time to detect (MTTD) security incident (cel: koniec M9)
- └─ <24h mean time to respond (MTTR) (cel: koniec M9)

Awareness (CISO → CEO):

- └─ >95% pracowników ukończyło training (cel: koniec M6)
- └─ <5% phishing click rate (cel: koniec M12)
- └─ >80% incidents reported w <1h (cel: koniec M12)

Compliance (CISO → Zarząd):

- └─ SOC2 Type II certified (cel: Wrzesień 2025)

- └ 0 RODO breaches (cel: ongoing)
- └ ISO 27001 certified (cel: Q4 2026)

Business (CEO):

- └ 0 klientów utraconych przez security (cel: ongoing)
- └ 100% klientów zadowolonych z security posture (surveys)
- └ Pozytywne case studies ("używamy własnego produktu")

RYZYKA PROJEKTU

Co może pójść nie tak:

Ryzyko	Prawdop	Mitigation
Nie znajdziemy dobrego CISO	Średnie	Headhunter, competitive salary
E5 upgrade za drogi	Niskie	ROI jasny, ale mamy fallback (CrowdStrike)
SOC2 nie na czas	Średnie	Start prep TERAZ, external help
Zespół przeciążony	Wysokie	Hire #2 DevOps early, CISO zdejmuje load
Kolejny incydent PODCZAS projektu	Niskie	Faza 1 = quick wins minimalizują

KOMUNIKACJA Z ZARZĄDEM

Quarterly updates do zarządu (1 slajd):

Q1 2025:

- └ Completed: Quick wins (Faza 1), 2 CRITICAL fixed
- └ In progress: CISO hire, SOC2 prep
- └ Metrics: 0 incidents, phishing rate 12% → 8%
- └ Budget: 50k PLN spent / 760k planned

Q2 2025:

- └ Completed: CISO onboarded, E5 deployed, SIEM live
- └ In progress: SOC2 audit, IaC migration
- └ Metrics: EDR 100%, phishing rate 8% → 5%
- └ Budget: 450k PLN spent / 760k planned

Q3 2025:

- └ Completed: SOC2 certified!, DevOps #2 hired
- └ In progress: ISO prep, continuous improvement
- └ Metrics: 0 CRITICAL vulns >30d, MTTD <1h
- └ Budget: 700k PLN spent / 760k planned

Q4 2025:

- └ Completed: Full program operational, bug bounty live
- └ Next: ISO 27001 (2026)
- └ Metrics: All green
- └ Budget: 760k PLN spent (on target)

